

Abuse of OAuth Integrations response

Identity / SaaS · **Critical** severity · SOC IR Playbook

Incident type	Third-Party App Abuse / Token-Based Account Compromise
Severity	Critical
Priority	Critical
Detection sources	SIEM, OAuth audit logs, Cloud identity platforms (e.g., Google Workspace, Azure AD), User reports, Threat intelligence feeds

Scenario

An attacker gains access to a user's cloud or application account by tricking them into authorising a malicious OAuth app (e.g., through phishing or social engineering). This gives persistent access without requiring login credentials, bypassing MFA in many cases.

MITRE ATT&CK

T1087, T1525, T1556.004

Preparation

Monitor OAuth authorisations
Enable logging for app consents and token grants
Limit third-party app permissions
Apply policies to restrict high-privilege access
Enforce admin consent workflows
Require security team approval for risky OAuth scopes
Educate users on phishing risks
Highlight risks of authorising unknown apps
Integrate identity logs with SIEM
Correlate token activity and app installations

Detection & Analysis

Detect suspicious app consent
OAuth app requesting abnormal permissions or used widely across accounts
Review audit logs
Check for tokens issued to unknown or recently created apps
Identify affected users
Map users who authorised the malicious app and assess data access scope
Investigate app behaviour
Determine if the app accessed email, files, cloud storage or contacts

Containment

Revoke app access
Remove the OAuth grant/token from affected accounts via admin portal or API
Block app at the tenant level
Ban the app's client ID in Google Workspace, Azure or GitHub settings
Disable impacted accounts (if needed)
If attacker used app access to escalate further
Notify users
Alert them about the revocation and potential data exposure

Eradication

Rotate access tokens and passwords
For users and service accounts if app accessed credentials or secrets
Clean up affected environments
Delete any backdoors, forwarding rules or uploaded files created via OAuth app
Strengthen tenant-wide policies
Restrict risky OAuth scopes (e.g., offline access, mail.readwrite, drive full access)
Update phishing protection
Block related phishing domains or links distributing the OAuth app

Recovery

Restore affected access
After confirming account is secure and OAuth app has been removed
Re-audit connected apps
Confirm no other high-risk apps are installed across users
Reinforce user MFA & session controls
Tighten identity policies (e.g., revoke sessions, require re-authentication)
Resume business operations
Once no further risk from the malicious integration remains

Lessons Learned & Reporting

Conduct impact analysis
What data was accessed or shared by the app? Over what timeframe? Report if necessary
To legal, compliance, regulators (e.g., PDPA, GDPR) or customers
Update consent policies
Require tighter admin control for risky app scopes
Share incident details internally
Raise awareness and update security

awareness training materials Improve detection logic Tune SIEM or SOAR playbooks to detect high-risk OAuth grants and anomalies

Tools typically involved

Cloud admin consoles (e.g., Google Workspace Admin, Azure AD Portal, Microsoft 365 Defender; Identity Protection (e.g., Okta, Duo, Conditional Access); SIEM (e.g., Splunk, Sentinel, QRadar); Cloud security tools (e.g., Microsoft Defender for Cloud Apps, G Suite Alert Center); Threat intelligence for phishing and app reputation

Success metrics (SLA targets)

Detection Time <15 minutes from risky app grant App Revocation Time <30 minutes from identification User Notification Time <1 hour for affected users OAuth Policy Enforcement 100% of users behind admin-consented model (for sensitive scopes) Incident Resolution Time Within 24-48 hours post-discovery